



Paolo Tresso June 16, 2026

PSA: Supply Chain Compromise Targets ShapedPlugin, Backdoored Pro Plugins Distributed via Official Channels

The Wordfence Threat Intelligence Team was notified on June 11th, 2026 of a potential supply chain compromise affecting ShapedPlugin, a WordPress plugin vendor with over 400,000 active free plugin installations. Fortunately, Wordfence customers have already had malware signature detection for the particular backdoor used in this attack.

During our investigation, we discovered that attackers compromised the vendor's build and distribution pipeline, injecting backdoor code into Pro plugin releases distributed

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

ACCEPT ALL REJECT ALL

Cookie Settings

compromises are becoming significantly more common in all software, including WordPress software.

The ShapedPlugin's team was notified by a Wordfence customer the same day their customer notified our team. In addition, our team reached out to the ShapedPlugin team on June 15th, 2026, after our team confirmed and analyzed the compromise. The ShapedPlugin's team released a statement on June 16th, 2026:

> "We confirm that we have received your notification and have taken this issue very seriously. Our team immediately initiated an investigation upon identifying the concern, and we have already implemented the necessary measures to mitigate the issue. Our security team is actively working to thoroughly analyze the reported indicators, review our distribution and release processes, and ensure the integrity of our products and infrastructure.
>
> As part of our response, we are currently preparing updated plugin releases and conducting comprehensive security reviews and validation tests to ensure that all affected products are fully addressed before deployment. We expect to release new verified versions once these checks have been completed successfully."

Two additional malware detection signatures were developed and released after undergoing our QA process between April 18th, 2026 and May 21st, 2026. All Wordfence Premium, Care, and Response [illegible] immediately, along with paid Wordfence CLI users. Users of the free version of Wordfence and Wordfence CLI received the same signatures after the standard 30-day delay.

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

Multiple ShapedPlugin Plugins < (Various Versions) - Backdoored Software 9.8

Wordfence

CVSS Rating	CVE-ID	Patch Status
9.8 (Critical)	CVE-2026-10735	Partially Patched

Affected Software

Product Slider Pro for WooCommerce *[woo-product-slider-pro]*

Real Testimonials Pro *[testimonial-pro]*

Smart Post Show Pro *[smart-show-post-pro]*

Researcher

Shane

Multiple plugins by ShapedPlugin contain a backdoor in various versions. This makes it possible for unauthenticated attackers to achieve backdoor access to sites with the compromised copy of the software installed. CVE-2026-49777 is a duplicate of this CVE.

More Details >

As part of our product lineup, we offer security monitoring and malware removal services to our Wordfence Care and Response customers. In the event of a security incident, our incident response team will investigate the root cause, find and remove malware from your site, and help with other complications that may arise as a result of an infection. During the cleanup, malware samples are added to our Threat Intelligence database, which contains over 4.4 million unique malicious samples. The Wordfence plugin and Wordfence CLI scanner detect over 99% of malware samples and thousands of compromises, when using the Extended Malware Signatures. Wordfence CLI can also clean sites if WordPress is no longer functional and is an excellent layer of security to implement at the server-level, part of our mission to secure the web by Defense in Depth.

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

Wordfence

Backdoored ShapedPlugin and Distribution Channels

ShapedPlugin, LLC maintains a portfolio of WordPress plugins spanning carousels, sliders, testimonials, accordions, and other UI components. Their free plugins are distributed through the WordPress.org plugin repository, while Pro versions are sold and distributed via Easy Digital Downloads (EDD) via account.shapedplugin.com.

The compromise only affects Pro plugin builds distributed through the vendor's EDD infrastructure, not the free plugins on WordPress.org. The attacker had selective access to inject malware only into commercially licensed releases.

A related backdoor in ShapedPlugin's Product Slider Pro for WooCommerce was assigned CVE-2026-49777 and reportedly patched in version 3.5.4. However, our investigation confirms that compromised packages continue to be distributed across other Pro products. We obtained a backdoored copy of Real Testimonials Pro 3.2.5 directly from the official vendor update endpoint on June 12nd, 2026.

Malware Analysis

Stage 1: The Loader

modified `src/Includes/TestimonialPRO.php` that loads it on every admin page:

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

```
add_action(
    'admin_init',
    function () {
        $installer = SP_TPRO_PATH . 'Includes/LicenseLoader.php';
        if ( file_exists( $installer ) ) {
            require_once $installer;
        }
    }
);
```

Once triggered, LicenseLoader.php performs several actions:

1. Downloads a payload from the C2 server at `194.76.217.28:2871`
2. Installs and activates it as a fake plugin using WordPress's `Plugin_Upgrader` class
3. Reports the victim domain back to the C2
4. Removes itself and cleans the loader hook from TestimonialPRO.php to cover its tracks

This self-deleting behavior means the initial infection vector disappears after first execution, complicating forensic analysis for site owners who notice the infection later.

Stage 2: The Dropped Payload

The downloaded payload installs as `wp-content/plugins/woocommerce-subscription/`. Note the singular "subscription" versus the legitimate WooCommerce Subscriptions plugin which uses the plural form. We also observed a variation called `woocommerce-notification`, again in the singular form. This fake plugin bundles multiple attack tools:

File	Function
woocommerce-subscription.php	Main plugin file, hides plugin from admin list
install-persistent.php	Persistence layer, REST API backdoor, data exfiltration
class-wc-admin-template.php	Tiny File Manager 2.6
class-wc-admin-bundler.php	c99shell v1.0
class-wc-subscription-trace-dispatch.php	Credential and 2FA secret stealer
class-wc-subscription-scheduler.php	Backdoor login bypass

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

The fake plugin immediately hides itself from the WordPress admin plugin list via the `all_plugins` filter, making visual detection difficult, an important reminder of the value in malware scanners.

Credential Theft and 2FA Secret Exfiltration

The file `class-wc-subscription-trace-dispatch.php` hooks into WordPress authentication to capture credentials in plaintext. It intercepts both `wp_authenticate` and `wp_login` actions to collect:

- Username and password
- User IP address and User-Agent
- Session cookies
- User roles and capabilities

What makes this variant particularly concerning is its targeted exfiltration of two-factor authentication secrets. The malware specifically searches for TOTP seeds from multiple 2FA plugins:

```
// Targeted 2FA plugins and their storage locations:
// - WP 2FA: wp_2fa_totp_key (user meta)
// - Wordfence Login Security: wfls_2fa_secrets (custom table)
// - Really Simple SSL 2FA: rsssl_totp_secret (user meta)
// - Two-Factor plugin: _two_factor_totp_key (user meta)
```

Stolen credentials and 2FA secrets are exfiltrated to `generate.2faplugin.org`, a domain clearly chosen to blend in with legitimate 2FA-related traffic. With both passwords and TOTP seeds in hand, attackers can bypass multi-factor authentication entirely, even if victims change their passwords after discovering the compromise.

Multiple Backdoor Access Methods

The payload establishes several persistent access channels:

REST API Backdoor: The `install-persistent.php` file registers a custom REST endpoint at `/wp-`

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

`json/wc/v3/settings/apply` that accepts arbitrary file writes when provided with the correct authentication token:

Wordfence

```
// POST /wp-content/install-persistent.php?json/wc/v3/settings/apply
// Parameters:
//   a = auth token (MD5 verified)
//   b = base64-encoded payload
//   f = target file path
```

URL Parameter Webshell: The diagnostics file accepts commands via URL parameters, supporting multiple execution methods:

```
// Parameters: k (auth token), d (base64 command), t (execution type)
// Types: s (shell_exec), e (exec), p (passthru), ph (eval)
```

Bundled Tools: Direct access to Tiny File Manager 2.6 and Adminer 5.2.1 provides attackers with convenient GUI-based file and database management.

Login Bypass: A hardcoded MD5 hash (`e268c35a06d85f672e70c9beecb4e5d1`) allows authentication bypass for any valid username: the attacker can log in as any administrator without knowing their password.

Data Exfiltration

When accessed directly, `install-persistent.php` displays a styled HTML page containing:

- Full contents of `wp-config.php` (database credentials, auth keys, debug settings)
- All administrator accounts with registration dates
- Mail plugin credentials from WP Mail SMTP, Post SMTP, Easy WP SMTP, and others
- WooCommerce order data from the last 3 months with payment method breakdown

After displaying this information, the file self-deletes.

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

Anti-Forensics

The malware employs several techniques to evade detection and complicate incident response:

- **Timestamp spoofing**: Uses touch commands to match file modification times with nearby legitimate plugin files
- **Self-deletion**: The loader removes itself after first execution
- **Plugin list manipulation**: Hides itself from the WordPress admin plugin list
- **Function obfuscation**: Sensitive function names like `shell_exec` are constructed via `chr()` arrays:

```
// Obfuscated function name construction
$fn = array_map('chr', [115,104,101,108,108,95,101,120,101,99]);
$func = implode('', $fn); // "shell_exec"
```

Evidence of Pipeline Compromise

Several factors indicate this could be a CI/CD pipeline compromise rather than simple package tampering.

Surgical File Modification

Analysis of file timestamps within the compromised ZIP reveals a precise injection pattern:

Date	File Count	Significance
2025-04-22	366	Original legitimate build baseline
2026-02-25	100	Legitimate release update
2026-05-21	4	**Backdoor injection**
2026-05-23	3	Post-injection version bump

Only 4 files were modified on May 21st, 2026 within a 2-hour window, consistent with an automated build step that injects the backdoor, not manual tampering.

Git Build Artifacts

The Pro plugin ZIP contains composer metadata with a git SHA reference:

```
// vendor/composer/installed.php
```

This confirms the package was built from a private Git repository, aligning with SVN commit messages that reference "Update from GitHub."

SVN Committer Pattern Change

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

WordPress.org SVN logs reveal a notable shift in April 2026. Seven free plugins were batch-deployed to WordPress.org between April 9th and April 15th, 2026 under the `shapedplugin` committer account, all referencing "Update from GitHub". The ShapedPlugin GitHub organization has no public repositories, indicating a private build pipeline.

Selective Injection

The attacker had access to deploy updates to both WordPress.org (free plugins) and the EDD system (Pro plugins), yet chose to only inject malware into some Pro builds. This selective approach suggests either:

- Awareness that WordPress.org has malware scanning that might detect the payload
- Targeting of paying customers who represent higher-value victims
- An attempt to delay detection by keeping the more-visible free plugins clean

Scope of Compromise

Confirmed Compromised

- **Real Testimonials Pro 3.2.5** — confirmed on June 12th, 2026
- **Product Slider Pro** (versions before 3.5.4) – CVE-2026-49777
- **Smart Post Pro** (versions before 4.0.2) – CVE-2026-10735

Potentially Affected

We examined current versions of all other ShapedPlugin Pro plugins available as of June 15th, 2026. None contained the LicenseLoader.php backdoor or associated C2 indicators. We cannot determine whether earlier versions of these plugins were compromised, but bundle packages (WooCommerce Bundle, All Plugins Bundle, WordPress Bundle) may also be affected.

Given that Product Slider Pro was confirmed compromised before 3.5.4 and has since been patched, site owners who

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

installed any ShapedPlugin Pro plugin between April and June 2026 should treat their sites as potentially compromised and [illegible] below.

C2 Infrastructure

IP/Domain	Purpose
194.76.217.28:2871	Payload delivery, victim beacon
generate.2faplugin.org	Credential exfiltration

Both IP addresses are registered to AEZA GROUP LLC and appear to be related with Russian-based entities. The domain `2faplugin.org` was updated on May 10th, 2026 shortly before the backdoor injection timestamps.

Timeline

Date	Event
2025-05-03	Earliest payload file timestamp (Adminer 5.2.1)
2026-03-16	Tiny File Manager added to payload
2026-03-25	Last SVN commit by rubel_miah
2026-04-08/15	Batch SVN commits by shapedplugin across 7 free plugins
2026-05-09	Credential stealer and persistence layer finalized
2026-05-10	2faplugin.org domain updated
2026-05-18	First known victim infections (cache poisoning)
2026-05-21	LicenseLoader.php injected into Pro builds
2026-05-21	CVE-2026-49777 reported to Patchstack
2026-06-04	CVE-2026-49777 disclosed
2026-06-10	Wordfence customer observed infection following Real Testimonials Pro update
2026-06-12	Compromised package obtained from vendor endpoint

This website uses cookies, pixels, and similar technologies (collectively “Cookies”) to improve your browsing experience. By clicking “Accept All”, you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

Indicators of Compromise

Type	Value
Loader hash	0e17c869d3e4586d4c160041042bd15123c2a37117a98a995fae885f0f4417fc (LicenseLoader.php)
Exfil domain	generate.2faplugin.org
REST endpoint	/wp-json/wc/v3/settings/apply
Fake plugin path	wp-content/plugins/woocommerce-subscription/
DB option	wp_options: theme_options_scripts
DB option	wp_options: wc_nf_install_done
Login bypass MD5	e268c35a06d85f672e70c9beecb4e5d1

Wordfence

Recommendations

If you have installed any ShapedPlugin Pro product:

1. **Scan immediately** using Wordfence or Wordfence CLI with premium signatures
2. **Check for the fake plugin** at
    1. `wp-content/plugins/woocommerce-subscription/`
    2. `wp-content/plugins/woocommerce-notification/`
    3. or similar suspicious variant
3. **Review wp_options** for theme_options_scripts and wc_nf_install_done entries
4. **Rotate all credentials** including WordPress admin passwords, database credentials, and any API keys in wp-config.php
5. **Revoke and regenerate 2FA secrets** for all users: existing TOTP seeds may be compromised
6. Check mail plugin configurations for modified SMTP credentials

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

Conclusion

This supply chain attack demonstrates the evolving threat landscape facing WordPress site owners. The attackers did not [illegible] the plugin code itself: they compromised the vendor's build and distribution infrastructure, turning legitimate licensed updates into malware delivery vehicles.

The inclusion of 2FA secret exfiltration marks a concerning evolution in WordPress-targeted malware. Attackers are no longer satisfied with stealing passwords alone; they are actively hunting the authentication factors that site owners deploy as additional security layers.

Site owners using ShapedPlugin Pro products should treat this as an active compromise and take immediate remediation steps. We will update this post as more information becomes available.

Wordfence Premium, Care and Response users, as well as paid Wordfence CLI customers, received malware signatures to detect this supply chain compromise between April 18th, 2026 and May 21st, 2026. Wordfence free users and Wordfence CLI free users received these signatures after a 30-day delay.

Wordfence

Search the blog SEARCH



This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

Wordfence includes an endpoint firewall, malware scanner, robust login security features, live traffic views, and more. Join over 5 million WordPress sites put their trust in Wordfence.

Wordfence

PROTECT YOUR SITE

Did you enjoy this post? Share it!

Comments

1 Comment

Cris *
June 24, 2026
7:27 am

Great analisys, and what a bunch of fine techniques they're using nowadays?!? Keep up the good work Wordfence

Speak to World-Class Security Research in your inbox as it happens.

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

you@example.com

By checking this box I agree to the terms of service and privacy

Wordfence

protected by reCAPTCHA

SIGN UP

Our business hours are 9am-8pm ET, 6am-5pm PT and 2pm-1am UTC/GMT excluding weekends and holidays.
Response customers receive 24-hour support, 365 days a year, with a 1-hour response time.

Terms of Service

Privacy Policy and Notice at Collection

Do Not Sell or Share My Personal Information

Products

Wordfence Free
Wordfence Premium
Wordfence Care
Wordfence Response
Wordfence CLI
Wordfence Intelligence

Support

Documentation
Learning Center
Free Support
Premium Support

Blog
In The News
Vulnerability Advisories

About Wordfence
Affiliate Program
Employment

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

Stay Updated

Sign up for news and updates from our panel of experienced security professionals.

you@example.com

By checking this box I agree to the terms of service and privacy policy.*

protected by reCAPTCHA

SIGN UP

© 2012-2026 Defiant Inc. All Rights Reserved

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.